

TELECARE

Plateforme de Télémédecine

POLITIQUE DE GESTION DES INCIDENTS DE SÉCURITÉ

Référentiel : HDS — Hébergement de Données de Santé | RGPD
Version 1.0 — Mars 2025

Document	Politique de Gestion des Incidents de Sécurité
Organisation	TeleCare SAS
Référentiels	HDS (ANS), RGPD (Art. 33-34), ISO/IEC 27035
Version	1.0
Date d'émission	Mars 2025
Statut	Applicable
Classification	Confidentiel — Usage interne
Propriétaire	RSSI — TeleCare
Approbateur	Direction Générale — TeleCare

1. Objet et périmètre

1.1 Objet

La présente politique définit le cadre organisationnel et les procédures appliquées par TeleCare pour détecter, qualifier, gérer et clôturer tout incident de sécurité affectant son système d'information, et en particulier les données de santé qu'elle héberge et traite.

Elle établit les rôles, les délais d'action, les critères de qualification, les obligations de notification réglementaire et les modalités de retour d'expérience. Elle s'inscrit dans les exigences de la certification HDS (Hébergement de Données de Santé) et du RGPD, qui imposent des obligations précises en matière de gestion et de notification des incidents affectant des données de santé à caractère personnel.

1.2 Périmètre

Cette politique s'applique à tout incident — avéré ou suspecté — affectant :

- La plateforme de télémédecine TeleCare et ses composants applicatifs
- Les API d'échange avec les établissements de santé et les partenaires
- L'infrastructure cloud hébergeant les données de santé
- Les postes de travail et équipements des collaborateurs
- Les accès des prestataires et sous-traitants

Elle s'impose à l'ensemble des collaborateurs, prestataires et partenaires de TeleCare.

2. Définitions et classification des incidents

2.1 Définitions

Terme	Définition
Événement de sécurité	Toute occurrence identifiée d'un état de système, de service ou de réseau indiquant une possible violation de la politique de sécurité ou l'échec de contrôles de sécurité (tentative de connexion échouée, alerte WAF, scan réseau, etc.)
Incident de sécurité	Un ou plusieurs événements de sécurité indésirables ou inattendus présentant une probabilité significative de compromettre les activités de TeleCare ou de menacer la confidentialité, l'intégrité ou la disponibilité des données de santé
Violation de données de santé	Incident entraînant, de façon accidentelle ou illicite, la destruction, la perte, l'altération, la divulgation non autorisée ou l'accès non autorisé à des données de santé à caractère personnel (définition RGPD Art. 4(12))
Incident majeur	Incident ayant ou pouvant avoir un impact significatif sur la continuité de service de TeleCare, sur un volume important de données de santé, ou nécessitant une notification aux autorités compétentes

2.2 Classification des incidents par niveau de gravité

Tout incident détecté est qualifié selon la grille de classification suivante, qui détermine la procédure de réponse applicable :

Niveau	Désignation	Critères caractéristiques	Exemples chez TeleCare
P1 — Critique	Majeur	Impact direct sur des données de santé, arrêt de service, compromission avérée	Exfiltration de dossiers patients, ransomware sur l'infrastructure, accès non autorisé massif à des données de santé
P2 — Élevé	Sérieux	Impact potentiel sur des données de santé, dégradation de service significative	Compte administrateur compromis, vulnérabilité critique exploitable en production, indisponibilité de la plateforme > 1h
P3 — Modéré	Modéré	Impact limité, pas de données de santé compromises avérées, service dégradé	Tentatives de phishing ciblées, scan de vulnérabilités détecté, accès suspect sur un compte utilisateur isolé
P4 — Faible	Mineur	Aucun impact sur les données de santé, impact opérationnel négligeable	Perte d'un équipement sans données sensibles, violation mineure de la charte informatique

3. Rôles et responsabilités

Acteur	Responsabilités dans la gestion des incidents
Tout collaborateur / utilisateur RSSI	Signalement immédiat de tout événement suspect au RSSI — premier maillon de la chaîne de détection Réception et qualification des signalements, coordination de la réponse, décision de notification réglementaire, pilotage du retour d'expérience, tenue du registre des incidents
Responsable Technique / CTO	Coordination des actions techniques de confinement et de remédiation, mobilisation des équipes DevOps et sécurité
DPO	Évaluation de l'impact sur les données de santé, pilotage des notifications CNIL et ANS, information des personnes concernées
Direction Générale Équipe DevOps / Ingénierie Astreinte sécurité	Décision d'escalade majeure, communication externe institutionnelle, arbitrage des priorités en situation de crise Actions techniques de confinement, d'investigation et de remédiation selon les instructions du RSSI Disponibilité 24h/24 pour les incidents P1 et P2 — numéro d'astreinte défini et maintenu à jour

4. Procédure de gestion des incidents

4.1 Vue d'ensemble des phases

La gestion d'un incident de sécurité chez TeleCare suit six phases séquentielles, depuis la détection jusqu'au retour d'expérience :

#	Phase	Responsable	Actions clés
1	Détection & Signalement	Tout utilisateur / Supervision	Signalement au RSSI via canal dédié, description des faits observés, horodatage
2	Qualification	RSSI	Vérification de l'incident, attribution du niveau P1-P4, ouverture du ticket d'incident, notification initiale selon le niveau
3	Confinement	RSSI + Équipe technique	Actions immédiates pour limiter la propagation : isolation de systèmes, révocation d'accès, blocage d'IP
4	Investigation	RSSI + DevOps + Sécurité	Analyse des causes, étendue de l'impact, données affectées, chronologie des événements
5	Remédiation	Équipe technique	Correction de la cause racine, restauration des systèmes, vérification de l'intégrité des données
6	Clôture & REX	RSSI + DPO	Rapport d'incident, retour d'expérience, mise à jour des contrôles, notification de clôture aux parties prenantes

4.2 Délais de traitement par niveau de gravité

Niveau	Délai de qualification	Délai de confinement initial
P1 — Critique	30 minutes maximum (24h/24, 7j/7)	2 heures maximum — astreinte mobilisée immédiatement
P2 — Élevé	2 heures (heures ouvrées) / 4h (hors ouvrées)	8 heures maximum
P3 — Modéré	Prochain jour ouvré	72 heures maximum
P4 — Faible	5 jours ouvrés	Selon planification corrective

4.3 Phase 1 — Détection et signalement

La détection peut provenir de plusieurs sources :

- Signalement manuel d'un collaborateur, d'un prestataire ou d'un partenaire
- Alerte automatique issue de la supervision (SIEM, WAF, monitoring cloud)
- Découverte lors d'un audit ou d'un test d'intrusion
- Notification par un tiers (chercheur en sécurité, établissement de santé partenaire, ANS)

Canal de signalement officiel TeleCare

- E-mail d'astreinte sécurité : securite@telecare.fr (surveillé 24h/24)
- Ticket dans l'outil ITSM interne : catégorie « Incident de Sécurité »
- Téléphone d'astreinte RSSI (numéro disponible sur l'intranet) — pour les incidents P1 uniquement
- En cas de doute sur la nature de l'événement, signaler quand même : mieux vaut une fausse alerte qu'un incident non détecté

4.4 Phase 2 — Qualification

À réception d'un signalement, le RSSI procède à la qualification de l'incident selon les critères suivants :

- Nature de l'incident : intrusion, malware, accès non autorisé, fuite de données, déni de service, erreur humaine...
- Données de santé potentiellement affectées : nature, volume, catégorie de personnes concernées
- Impact sur la disponibilité de la plateforme et les consultations en cours
- Origine supposée : interne, externe, prestataire, partenaire hospitalier

Un ticket d'incident est ouvert dans l'outil ITSM dès la qualification confirmée. Il est mis à jour en continu jusqu'à la clôture.

4.5 Phase 3 — Confinement

Les actions de confinement visent à limiter la propagation de l'incident sans détruire les preuves nécessaires à l'investigation. Selon le type d'incident, les actions peuvent inclure :

- Isolation réseau d'un système compromis
- Révocation immédiate des accès d'un compte compromis
- Blocage d'une IP ou d'un range d'adresses malveillantes au niveau WAF et pare-feu
- Suspension temporaire d'une API ou d'un endpoint compromis
- Activation du mode dégradé de la plateforme si nécessaire pour préserver les consultations en cours

Principe fondamental de confinement

- Avant toute action de confinement, capturer et préserver les preuves : journaux système, images mémoire, captures réseau.

- Toute action de confinement est documentée en temps réel dans le ticket d'incident avec son horodatage et son auteur.
- En cas de doute entre préserver les preuves et stopper l'incident, contacter immédiatement le RSSI pour arbitrage.

4.6 Phase 4 — Investigation

L'investigation vise à déterminer la cause racine, l'étendue de l'impact et la chronologie précise de l'incident. Elle repose sur :

- L'analyse des journaux d'accès à la plateforme et aux données de santé
- L'analyse des logs système, réseau et applicatifs
- L'identification des données de santé potentiellement exposées (périmètre, volume, sensibilité)
- La reconstruction de la chronologie des événements
- L'identification de l'origine et des vecteurs d'attaque

Les conclusions de l'investigation alimentent directement la décision de notification réglementaire (CNIL, ANS) et les actions de remédiation.

5. Obligations de notification réglementaire

5.1 Arbre de décision de notification

Dès la qualification d'un incident impliquant des données de santé à caractère personnel, le RSSI et le DPO évaluent conjointement les obligations de notification selon l'arbre de décision suivant :

Étape 1 — L'incident constitue-t-il une violation de données de santé à caractère personnel ?

- OUI → passer à l'étape 2
- NON → aucune notification RGPD requise, documenter dans le registre des incidents

Étape 2 — La violation est-elle susceptible d'engendrer un risque pour les droits et libertés des personnes ?

- OUI → Notification à la CNIL dans les 72 heures suivant la prise de connaissance (Art. 33 RGPD)
- NON → Pas de notification CNIL requise, mais documentation obligatoire dans le registre

Étape 3 — La violation est-elle susceptible d'engendrer un risque ÉLEVÉ pour les personnes ?

- OUI → Information des patients concernés sans délai indu (Art. 34 RGPD), en plus de la notification CNIL
- NON → Notification CNIL seule (si risque simple confirmé à l'étape 2)

Étape 4 — L'incident affecte-t-il des données hébergées sous certification HDS ?

- OUI → Notification à l'ANS (Agence du Numérique en Santé) sans délai indu, en parallèle de la notification CNIL
- Information des établissements de santé partenaires dont les données sont concernées

5.2 Délais et contenus des notifications

Destinataire	Délai	Contenu minimal
CNIL	72 heures après prise de connaissance	Nature de la violation, catégories et nombre approximatif de personnes et d'enregistrements concernés, coordonnées du DPO, conséquences probables, mesures prises

ANS	Sans délai indu (recommandé : 24-48h)	Nature et périmètre de l'incident, données de santé concernées, mesures de confinement engagées, plan de remédiation
Patients concernés	Sans délai indu si risque élevé	Description claire de la violation, coordonnées du DPO, conséquences probables, mesures recommandées pour se protéger
Établissements partenaires	Selon engagements contractuels (max 48h)	Nature de l'incident, données concernées, mesures prises, impact sur leurs systèmes

Si les 72 heures ne permettent pas de disposer de toutes les informations requises, la notification initiale à la CNIL est transmise avec les éléments disponibles, complétée dès que possible.

6. Registre des incidents

TeleCare tient un registre centralisé de l'ensemble des incidents de sécurité, qu'ils aient ou non donné lieu à une notification réglementaire. Ce registre est obligatoire au titre du RGPD (Art. 33(5)) et de la certification HDS.

Pour chaque incident, le registre contient :

- Identifiant unique et date d'ouverture du ticket
- Description de l'incident et classification (P1 à P4)
- Chronologie détaillée : détection, qualification, confinement, remédiation, clôture
- Données de santé concernées : nature, volume estimé, catégories de personnes
- Actions de réponse mises en oeuvre et leurs horodatages
- Décisions de notification et justifications documentées
- Causes racines identifiées et mesures correctives appliquées
- Statut de clôture et date de clôture

Le registre est maintenu par le RSSI, accessible au DPO et à la Direction Générale. Il est mis à disposition des auditeurs HDS et de la CNIL sur demande. Les entrées sont conservées pendant 5 ans minimum.

7. Retour d'expérience et amélioration continue

7.1 Rapport post-incident

Tout incident de niveau P1 ou P2 fait l'objet d'un rapport post-incident (Post-Incident Review) rédigé par le RSSI dans un délai de 10 jours ouvrés après la clôture. Ce rapport comprend :

- La chronologie complète et factuelle de l'incident
- L'analyse des causes racines (méthode des 5 Pourquoi ou équivalent)
- L'évaluation de l'efficacité de la réponse (détection, confinement, notification)
- Les mesures correctives et préventives identifiées, avec responsables et délais
- Les leçons apprises à partager avec les équipes concernées

Les incidents P3 font l'objet d'un résumé documenté dans le registre. Les incidents P4 sont documentés et revus lors de la réunion mensuelle sécurité.

7.2 Bilan périodique

- Un bilan mensuel des incidents est présenté par le RSSI à la Direction Technique
- Un bilan trimestriel est présenté à la Direction Générale, incluant les tendances, les incidents majeurs et l'état des plans de remédiation
- Les indicateurs suivis incluent : nombre d'incidents par niveau, délai moyen de qualification, délai moyen de résolution, taux de notifications réglementaires
- Les plans de remédiation issus des retours d'expérience sont suivis jusqu'à leur mise en oeuvre complète

7.3 Exercices de simulation

Des exercices de simulation d'incidents (« tabletop exercises ») sont organisés au minimum une fois par an, impliquant le RSSI, le DPO, la Direction Technique et la Direction Générale. Ces exercices visent à :

- Tester la réactivité et la coordination des équipes face à un scénario d'incident majeur
- Vérifier les délais de notification réglementaire dans des conditions simulées
- Identifier les lacunes organisationnelles ou documentaires de la procédure
- Former les nouveaux membres de l'équipe à la procédure de gestion des incidents

8. Approbation et entrée en vigueur

Rédigé par	RSSI — TeleCare
Vérifié par	DPO — TeleCare
Approuvé par	Direction Générale — TeleCare
Date d'approbation	Mars 2025
Date d'entrée en vigueur	Mars 2025
Prochaine révision	Mars 2026

Signature du RSSI	Signature Direction Générale
Nom : _____ Date : _____	Nom : _____ Date : _____